

System Design Document (SDD): AltoPilot

Enterprise HR & Benefits Agent Platform

****Document Metadata:****

*** **Document ID:**** SDD-ALTO-2026-01

*** **Author:**** Glen Francis (`glenfrancis@google.com`), Strategic Advisor & Principal Architect, Google Cloud APAC

*** **Status:**** PROPOSED / REVIEW READY

*** **Target Audience:**** Engineering Leads, Cloud Architects, Chief Information Officer (CIO), Chief People Officer (CPO)

*** **Date:**** September 2, 2026

*** **Version:**** 1.1.0 (Updated to incorporate Gemini Enterprise App as Primary Employee Channel)

*** **Repository:**** `https://github.com/glenfrancis-goog/alto-pilot`

*** **Target Environment:**** Google Cloud Platform (Argolis Project: `projectelevatelabs`, Org: `glenfrancis.altostrat.com`)

1. Executive Summary

Enterprise organizations operate under complex, fragmented, and legally binding labor regulations across multiple jurisdictions. In APAC alone, statutory employment baselines (such as Singapore's Ministry of Manpower mandates, Hong Kong Employment Ordinances, and Australian Fair Work regulations) define mandatory floors for paid sick leave, annual leave accrual, and government-paid parental benefits. Existing employee self-service portals suffer from high ticket resolution latencies, rigid form hierarchies, and a lack of conversational intelligence. Conversely, unconstrained Large Language Model (LLM) chatbots present severe enterprise risks: non-deterministic hallucinations of statutory benefits, lack of cryptographic non-repudiation, and absence of transactional state integration.

****AltoPilot**** is an autonomous, enterprise-grade HR and benefits agentic platform designed to resolve these limitations. Built on the ****Gemini Enterprise Agent Platform (GEAP)**** and ****Agent Development Kit (ADK)****, AltoPilot moves beyond informational Q&A into fully auditable, transactional execution.

Key Architectural Innovation: Dual-Channel Frontend Strategy

AltoPilot implements a **Dual-Channel Frontend Architecture**:

1. **Primary Employee Channel (Gemini Enterprise App):** Serves as the zero-friction, primary front door for all employees. AltoPilot is published into the corporate Gemini Enterprise app gallery, enabling employees to query policies and manage leave directly within their daily Google Workspace environment (Web, Google Chat, and Mobile) using native enterprise Single Sign-On (SSO).
2. **Secondary Embeddable Channel (A2UI / Cloud Run Web Runtime):** Exposes a lightweight FastAPI endpoint supporting Agent-to-User Interface (A2UI) streaming and Agent-to-Agent (A2A) protocol for embedding AltoPilot into legacy corporate intranets or ServiceNow portals.

Under the hood, AltoPilot provides:

- * **A Multi-Agent Mesh Architecture:** Decoupling user coordination, semantic policy retrieval, HRIS transactional mutations, and high-liability escalations.
- * **Tri-Modal Identity & Delegation:** Combining user OIDC authentication, cryptographic agent SPIFFE IDs, and Workload Identity Federation (WIF) for zero-trust per-tool authorization.
- * **Code-Guarded RAG & Statutory Floor Enforcement:** An algorithmic assertion layer guaranteeing that company policy answers strictly uphold or exceed statutory legal baselines without LLM drift.
- * **Two-Phase Commit (2PC) Transactions:** Structured confirmation cards ensuring explicit human consent before mutating external HRIS state.
- * **Immutable BigQuery Audit Ledger:** Scrubbed, distributed OpenTelemetry (OTel) telemetry ensuring full regulatory compliance and continuous evaluation.

2. Context & Background

AltoPilot originated as an experimental proof-of-concept under the Google Cloud Elevate Labs program, cataloging 155 specialized HR policy concepts across leave accruals, healthcare allowances, remote work taxation, and compassionate leave. While the initial prototype demonstrated 100% retrieval accuracy on held-out evaluation datasets using Gemini 2.5 Pro, field deployment scoping identified critical production gaps:

- * **Adoption Friction:** Requiring employees to navigate to a separate standalone web URL leads to low engagement and high IT portal fatigue.
- * **Read-Only Bottleneck:** Employees could ask about leave entitlements but could not seamlessly book them.
- * **Confused Deputy Risk:** API integrations used shared service accounts, preventing non-repudiation between human intent and automated tool execution.
- * **Liability in Gray Areas:** High-consequence requests (such as uncertified medical leave adjacent to public holidays or cross-border remote work exceeding tax residency thresholds) were answered textually without deterministic governance.

This design document formalizes the production architecture required to transform AltoPilot into an enterprise-ready system operated by a cross-functional engineering team of five engineers, leveraging the Gemini Enterprise App as the core employee engagement interface.

3. Goals & Non-Goals

3.1. Goals

* **G1: Turnkey Employee Access via Gemini Enterprise App:** Seamlessly register and surface AltoPilot in the corporate Gemini Enterprise app catalog via `agents-cli publish gemini-enterprise`, supporting `@AltoPilot` invocations across Web, Google Chat, and Mobile.

* **G2: Multi-Agent Specialization:** Implement a modular agent mesh separating conversational routing, policy comprehension, and API mutation.

* **G3: Zero-Trust Identity:** Enforce cryptographic agent identity (SPIFFE) and On-Behalf-Of (OBO) token exchange across all external tools.

* **G4: Algorithmic Compliance Assurance:** Provide 100% deterministic enforcement of regional statutory floors (e.g. Singapore MOM statutory leave floors) via pre-delivery validation hooks.

* **G5: Transactional Integrity:** Support idempotent, human-confirmed transactions against WorkWeek (HRIS/Payroll) and ServiceImmediately (Service Management).

* **G6: Regulatory Non-Repudiation:** Stream sanitized, immutable execution traces and tool logs to BigQuery with 7-year statutory retention.

* **G7: Developer Quality Flywheel:** Enforce CI/CD quality and security gates via CodeMender and automated synthetic regression evals.

3.2. Non-Goals

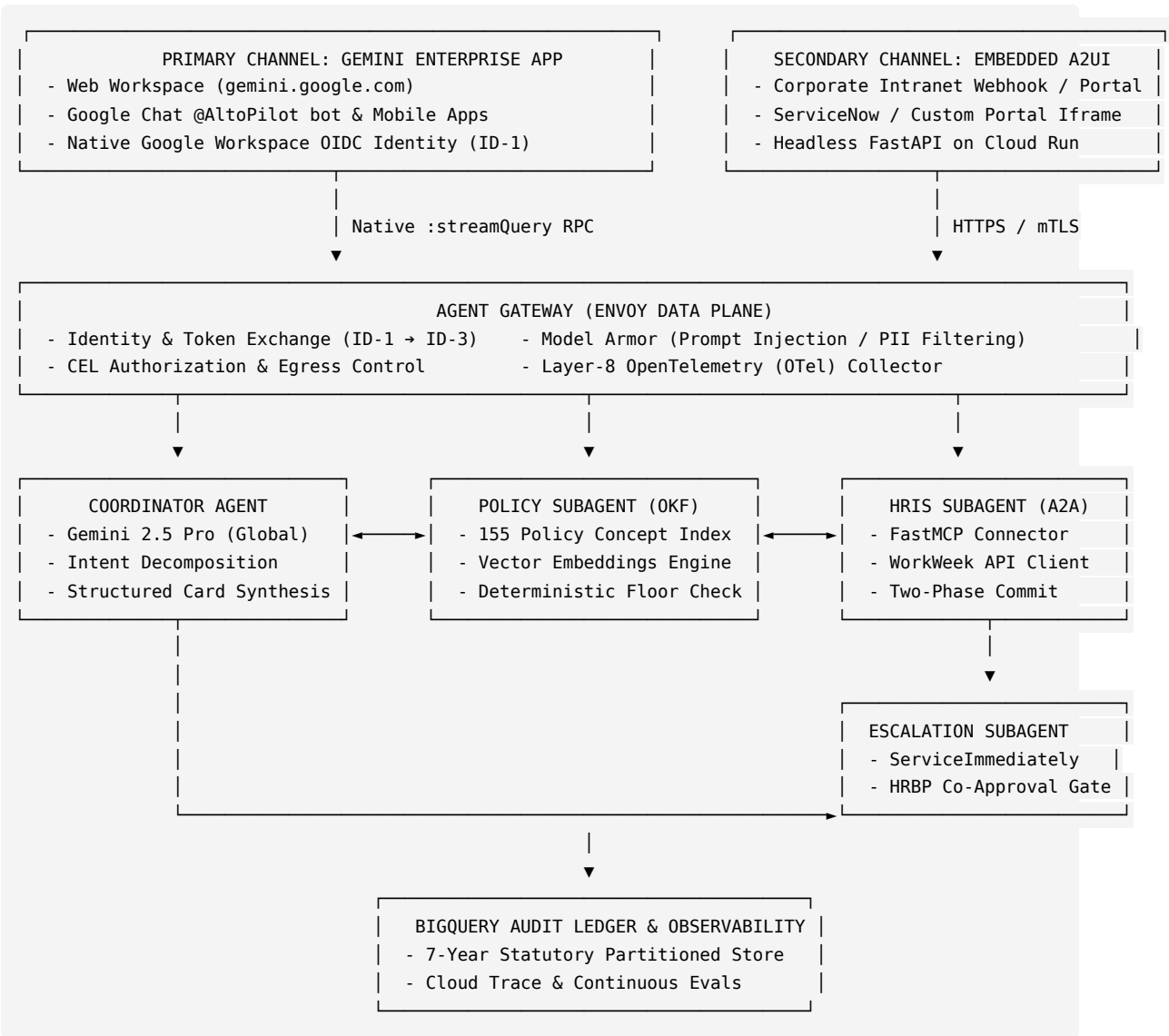
* **NG1:** Direct integration with raw bank clearing rails for payroll disbursement (handled exclusively within core HRIS batch cycles).

* **NG2:** Autonomous unilateral employee termination or disciplinary action (must remain an offline human management workflow).

* **NG3:** Replacing the underlying HRIS database as the primary system of record.

4. High-Level System Architecture

AltoPilot employs a dual-channel frontend architecture orchestrated via the **Agent Gateway** on Google Cloud.



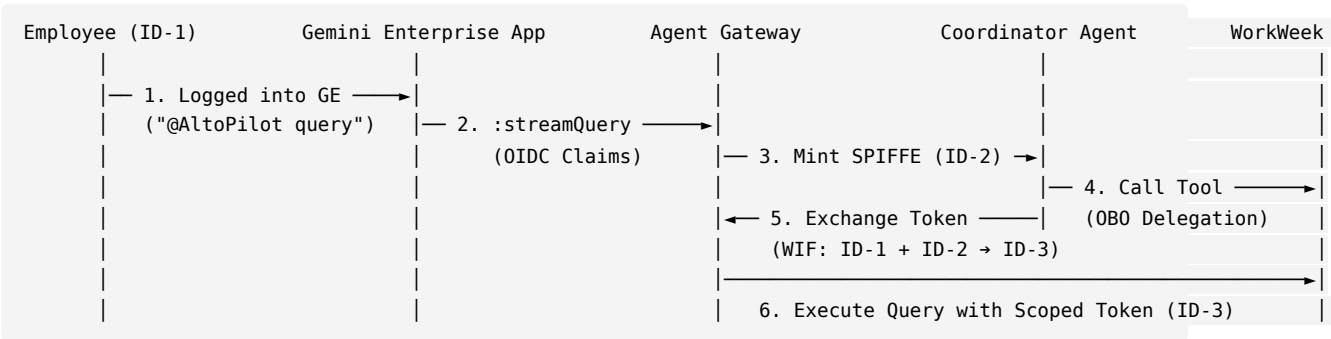
4.1. Core Components

1. **Gemini Enterprise App (Primary Front Door):** The managed enterprise conversational interface where employees interact with AltoPilot. Handles authentication, conversation state, mobile responsiveness, and Google Chat integration.
2. **Agent Gateway:** An Envoy-based managed proxy enforcing ingress/egress policies, Common Expression Language (CEL) authorization, and SPIFFE identity propagation.
3. **Coordinator Agent:** The central orchestration engine responsible for intent classification, session state management, and multi-agent synthesis.
4. **Policy Specialist Subagent:** Executes dense vector and lexical search across the 155 OKF policy concepts, enforcing jurisdictional statutory floors before emitting answers.
5. **HRIS Specialist Subagent:** Manages communication with WorkWeek for leave balances, employee master records, and transactional updates.
6. **Escalation Specialist Subagent:** Coordinates high-liability workflows in ServiceImmediately, provisioning human-in-the-loop tickets when policy boundaries require manager or HRBP approval.

5. Detailed Design & Core Interactions

5.1. Tri-Modal Identity & Delegation Sequence

To prevent confused-deputy attacks and ensure cryptographic non-repudiation, AltoPilot implements a tri-modal identity scheme:



1. **User Identity (\$ID_1\$):** Human principal authenticated via enterprise Google Workspace OIDC identity. The Gemini Enterprise app propagates verified claims (`email`, `user\_id`, `org\_unit`) in the invocation context.

2. **Agent Identity (\$ID_2\$):** Workload identity represented by a SPIFFE ID (`spiffe://altostrat.internal/ns/hr/sa/altopilot-coordinator`) embedded in mTLS certificates.

3. **Delegated Identity (\$ID_3\$):** Short-lived Downscoped Access Token minted via Workload Identity Federation (WIF) reflecting both the human principal and the agent ID. Third-party target systems log both identities in their internal audit records.

5.2. Registration & Publishing Lifecycle (GE App Integration)

AltoPilot is registered with the enterprise catalog using `agents-cli`:

```
# 1. Deploy ADK Agent to Vertex AI Agent Runtime
agents-cli deploy --target agent-runtime --project mba-codemender

# 2. Register with Gemini Enterprise App
agents-cli publish gemini-enterprise \
  --registration-type adk \
  --agent-runtime-id "projects/799659834628/locations/us-central1/reasoningEngines/altopilot-prod" \
  --gemini-enterprise-app-id "projects/799659834628/locations/global/collections/default_collection/engines/enterp
  --display-name "AltoPilot HR Assistant" \
  --description "Autonomous HR policy guidance, Singapore MOM statutory compliance, and leave bookings." \
  --tool-description "Answers employee policy queries, checks leave balances in WorkWeek, and submits leave reques
```

* **Administrative Governance Gate:** Once registered, AltoPilot enters the Gemini Enterprise Admin Console in `PENDING\_APPROVAL` status. An authorized Google Workspace / Cloud Administrator reviews the

tool scopes, policies, and target models before publishing it enterprise-wide.

5.3. Two-Phase Commit (2PC) in Gemini Enterprise Chat

Within the Gemini Enterprise conversational interface:

[Phase 1: Preparation & Draft Synthesis]

User: "@AltoPilot I had a baby yesterday, can you submit 4 days paternity leave starting Monday?"

- Coordinator queries Policy Subagent → Validates MOM statutory compliance
- Queries WorkWeek for Balance Check (20 days available)
- Emits Structured Markdown Draft Card:

```

| 📄 LEAVE SUBMISSION DRAFT: Paternity Leave (GPPL) |
| • Dates: Monday, 08 Sep 2026 - Thursday, 11 Sep 2026 (4 Days) |
| • Current Balance: 20 Days | Balance After: 16 Days |
| • Statutory Floor: Compliant with MOM Singapore 4-week rule |
| Reply "Confirm" to book in WorkWeek, or "Cancel" to abort. |

```

[Phase 2: Human Execution Gate & Commit]

User replies: "Confirm"

- AltoPilot verifies cryptographic session context
- High-liability threshold check:
 - └ Standard Leave (<= 5 days): Commits transaction to WorkWeek API → Emits confirmation receipt
 - └ Extended / High-Risk (> 14 days, uncertified sick leave, cross-border):
 - Opens ServiceImmediately Ticket #INC-94821 → Routes to HRBP for co-approval

5.4. Code-Guarded RAG & Statutory Floor Enforcement

LLMs must never be permitted to unilaterally calculate statutory minimums. AltoPilot separates semantic retrieval from mathematical policy validation:

```

def validate_policy_entitlement(
    employee_tenure_months: int,
    country_code: str,
    requested_leave_type: str,
    proposed_entitlement_days: int
) -> ValidationResult:
    """Deterministic policy compliance assertion hook."""
    statutory_floor = get_statutory_baseline(country_code, requested_leave_type, employee_tenure_months)

    # Assert company policy does not violate mandatory legal floor
    if proposed_entitlement_days < statutory_floor.mandatory_days:
        return ValidationResult(
            status=Status.BLOCKED,
            reason=f"LLM draft ({proposed_entitlement_days}d) violates statutory floor ({statutory_floor.mandatory_days}d)"
        )

    # Check conditional gotchas (e.g. uncertified sick leave adjacent to public holidays)
    gotchas = evaluate_gotcha_rules(country_code, requested_leave_type)

    return ValidationResult(
        status=Status.APPROVED,
        statutory_floor_days=statutory_floor.mandatory_days,

```

```

    active_gotchas=gotchas
)

```

6. Security, Privacy & Data Governance

6.1. Role-Based Access Control (RBAC) & PII Isolation

* **Least Privilege Scoping:** An Individual Contributor (IC) can only query their own leave balance, public policy concepts, and general benefits. They cannot view peer leave history, team health notes, or executive compensation structures.

* **Model Armor Sanitization:** All user prompts and agent responses pass through Google Cloud Model Armor:

* **Ingress:** Redacts employee NRIC/SSN, credit card numbers, and banking details. Detects indirect prompt injection and jailbreaks.

* **Egress:** Prevents unintended data exfiltration and suppresses unverified claims.

6.2. DevSecOps & CI/CD Guardrail Pipeline

Following our security guardrail pattern:

* **Pre-Commit Hooks:** Local validation using Semgrep to detect hardcoded credentials, unvalidated JSON deserialization, and path injection vulnerabilities in custom tool connectors.

* **CodeMender CI/CD Gate:** Automated scanning of PRs; any high-severity finding triggers automated sandboxed exploit verification and PR remediation before deployment to Cloud Run.

7. Observability, Telemetry & Evaluation Flywheel

7.1. OpenTelemetry (OTel) Distributed Tracing

AltoPilot instruments all interactions with Layer-8 Agentic OTel:

* **Trace Attributes:** `gen\_ai.agent.name`, `gen\_ai.prompt.tokens`, `gen\_ai.completion.tokens`, `gen\_ai.tool.name`, `gen\_ai.tool.duration\_ms`, `spiffe.identity`.

* **Distributed Propagation:** Trace contexts are propagated across Agent Gateway, subagents, and downstream FastMCP servers, terminating in Google Cloud Trace.

7.2. BigQuery Audit Ledger Schema

Interaction data is streamed in real-time to a partitioned BigQuery table
(`altopilot\_telemetry.audit\_ledger\_v1`):

Field Name	Type	Description
----	----	----
`event_id`	STRING	Unique UUID v4 for the interaction step
`timestamp`	TIMESTAMP	UTC timestamp of the execution
`session_id`	STRING	Client session identifier
`human_principal_hash`	STRING	SHA-256 pseudonymized employee identity
`agent_spiffe_id`	STRING	Cryptographic SPIFFE ID of the executing agent
`intent_class`	STRING	Classified user intent
`tool_calls`	ARRAY<RECORD>	Sequence of tools called with inputs and latency
`statutory_floor_verified`	BOOLEAN	Assertion flag from the deterministic rule engine
`tokens_consumed`	INT64	Total prompt + completion tokens
`action_status`	STRING	`READ_ONLY`, `DRAFTED`, `COMMITTED`, `ESCALATED`

7.3. The Quality Flywheel

Before any agent prompt, OKF policy update, or tool connector is promoted to staging:

- * The CI pipeline executes `evals/policy\_eval.py` against a 50-scenario held-out evaluation dataset.
- * Releases are blocked if semantic accuracy falls below **100%** on statutory floors or overall intent accuracy drops below **98%**.

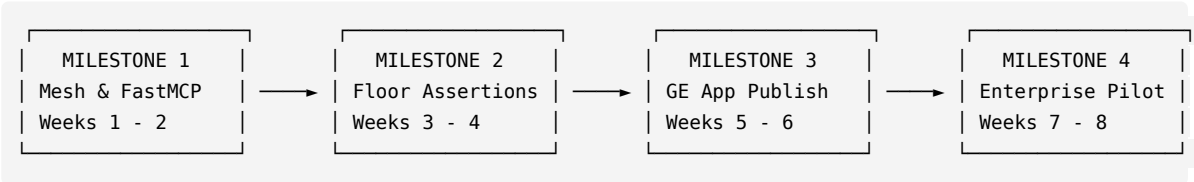
8. Cross-Functional Engineering Work Breakdown (Team of 5)

Role	Engineer	Core Responsibilities	Deliverables
----	----	----	----
System Architect / Tech Lead Glen Francis Overall system architecture, GEAP Agent Gateway topology, SPIFFE identity configuration, and cross-team alignment. SDD approval, Agent Gateway configuration, core orchestration engine.			
Integrations Engineer Engineer 2 Build and maintain FastMCP tool servers for WorkWeek (HRIS) and ServiceImmediately (Ticketing). `tools/workweek_mcp.py`, `tools/service_immediately_mcp.py`, mock test servers.			
Policy & Compliance Engineer Engineer 3 Indexing of 155 OKF policy concepts, deterministic statutory floor assertion engine, and legal rule ontology. `knowledge/` vectors, `rag/floor_validator.py`, APAC legal compliance matrix.			
DevSecOps Engineer Engineer 4 Gemini Enterprise App registration, Agent Runtime deployment, Secret Manager integration, CodeMender CI/CD guardrail. `deployment_metadata.json`, `agents-cli publish` automation, `.github/workflows/ci.yml`.			
QA & Evaluation Engineer Engineer 5 Design 50+ synthetic user scenarios, red-teaming prompt injection suites, automated regression benchmark runners. `evals/synthetic_suite.json`, `evals/policy_eval.py`, BigQuery quality dashboards.			

9. Alternatives Considered & Trade-Off Analysis

Architectural Decision	Chosen Option	Alternative Considered	Trade-Off Rationale
Frontend Strategy	Gemini Enterprise App as Primary Front Door	Custom Bespoke Web Portal Only	Building a custom web portal incurs high frontend maintenance, requires dedicated auth plumbing, and introduces high user friction. Gemini Enterprise provides native Google Workspace SSO, mobile/chat access, and turnkey corporate reach.
Mesh vs Monolith	Multi-Agent Mesh on GEAP	Single ReAct Monolithic Agent	A single monolith suffers from prompt bloat, high token costs, and catastrophic tool hallucinations when handling 20+ tool schemas simultaneously. The mesh isolates domains cleanly.
Identity Delegation	Tri-Modal SPIFFE + WIF	Central Service Account with Context Headers	Service account headers are trivial to spoof if any upstream gateway is compromised and fail enterprise non-repudiation audit standards.
Compliance Gating	Code-Guarded Deterministic Hook	Dual-Pass LLM Judge	A secondary LLM judge is still probabilistic, introduces 400ms additional latency, and can still hallucinate complex statutory conditions. Code assertions provide mathematical guarantees.
Mutating Writes	Two-Phase Commit (Draft → Confirm)	Immediate Execution with Undo	Immediate execution creates high operational overhead for HR teams to reverse unauthorized or accidental payroll/leave actions. Explicit confirmation eliminates accidental mutations.

10. Rollout, Milestones & Launch Criteria



- * **Milestone 1 (Weeks 1-2):** Deploy Coordinator Agent and FastMCP connectors for WorkWeek and ServiceImmediately in sandbox.
- * **Milestone 2 (Weeks 3-4):** Integrate 155 OKF concepts with deterministic statutory floor validation hooks for Singapore and Hong Kong.
- * **Milestone 3 (Weeks 5-6):** Implement Agent Gateway with Model Armor, SPIFFE identity exchange, and register AltoPilot with Gemini Enterprise App via `agents-cli publish`.
- * **Milestone 4 (Weeks 7-8):** Run 100-user internal pilot across Altostrat APAC Strategic Advisory teams via Google Chat and Gemini Enterprise web app; verify zero compliance drift and sub-500ms median latency.

Appendix: Architectural Sign-Off & Approvals

Reviewer	Title / Function	Status	Signature
----	----	----	----
Glen Francis	Strategic Advisor & Principal Architect	AUTHOR	*Glen Francis*
Engineering Lead	Cloud AI Solutions Engineering	PENDING REVIEW	_____
Chief Information Security Officer (CISO)	Information Security & Compliance	PENDING REVIEW	_____
VP of People Operations (CPO)	APAC Human Resources	PENDING REVIEW	_____

